

Sicherheit in Netzwerken

Risiken verstehen, Schutz
erklären, Kunden beraten

Agenda

- **Geschäftsrisiken** – warum Netzwerksicherheit alle Unternehmen betrifft
- **Orientierungsmodell** – wo Kommunikation angegriffen werden kann
- **Zugang und lokales Netz** – wer oder was darf sich verbinden?
- **Datenwege im Internet** – wem vertrauen wir beim Transport?
- **Verfügbarkeit von Diensten** – wie entstehen Überlastung und Ausfall?
- **Anwendungen und Sitzungen** – wie werden Nutzer umgeleitet oder übernommen?
- **Schutzkonzept und Beratung** – mehrere Schutzlinien sinnvoll kombinieren

Warum ist Netzwerksicherheit so wichtig?

Die Angriffsfläche der vernetzten Welt

Jedes Gerät hängt am Netzwerk

- Vernetzt sind nicht nur Laptops, sondern auch **Drucker, Maschinen, Kameras und Sensoren**
- Cloud-Dienste und Partner schaffen zusätzliche Verbindungen außerhalb des Unternehmens
- Jedes Gerät und jede Verbindung erweitert die **Angriffsfläche**
- Ein unauffälliges Gerät kann zum Einstieg in kritische Systeme werden

Geschäftsfrage: Wissen wir, welche Geräte mit unserem Netzwerk verbunden sind?

Zugriff von überall möglich

- Homeoffice, mobile Geräte und Cloud-Dienste lösen die klassische **Unternehmensgrenze** auf
- Angriffe sind weltweit möglich und rund um die Uhr automatisierbar
- Gestohlene Zugangsdaten oder ein ungeschütztes Gerät können den Einstieg ermöglichen
- Danach entscheidet die interne Abschottung über das Schadensausmaß

Merksatz: Ein Netzwerk ist nur so sicher wie sein schwächstes angeschlossenes Gerät.

Perimeter-Sicherheit reicht nicht mehr

Früher

- Klare Netzwerkgrenze (Perimeter)
- Firewall am Übergang zum Internet
- „Innen sicher, außen unsicher“

Heute

- Homeoffice, Cloud, mobile Geräte
- Keine klare Grenze mehr
- Prinzip **Zero Trust**: jede Verbindung wird geprüft, egal woher

Wo Kommunikation angegriffen werden kann

Das OSI-Modell als einfache Landkarte

Warum ein Schichtenmodell?

- Netzwerkkommunikation besteht aus mehreren aufeinander aufbauenden Aufgaben
- Das **OSI-Modell** ordnet sie vom physischen Zugang bis zur Anwendung
- Jede Ebene kann eigene Risiken und Schutzmaßnahmen haben
- Für Beratung und Vertrieb genügt eine vereinfachte Landkarte:
 - **Zugang – Transport – Anwendung**

Eine Landkarte in drei Bereichen

Bereich	Worum geht es?	Typisches Risiko
Anwendung	Webseiten, E-Mail, angemeldete Sitzungen	Täuschung oder Übernahme
Transport	Datenwege und Erreichbarkeit	Umleitung oder Überlastung
Zugang	Geräte, Kabel, WLAN, lokales Netz	Unbefugte Verbindung

Das technische OSI-Modell verfeinert diese Landkarte in sieben Schichten.

Vier Fragen als roter Faden

- **Ereignis:** Was kann bei der Kommunikation schiefgehen?
- **Auswirkung:** Welche Folgen entstehen für Kunden und Geschäft?
- **Schutz:** Welches Sicherheitsprinzip reduziert das Risiko?
- **Beratung:** Welche Frage macht den Handlungsbedarf sichtbar?

Technische Details erklären das Wie. Für Entscheidungen zählt zuerst das Warum.

Zugang und lokales Netz

Wer oder was darf sich verbinden?

Physischer Zugang ist Netzwerkzugang

- Frei zugängliche Netzwerkdosen können interne Verbindungen ermöglichen
- Unsicheres WLAN kann Daten preisgeben oder fremde Geräte hereinlassen
- Serverräume, Verteiler und Leitungen sind Ziele für Diebstahl oder Sabotage
- Schutz beginnt deshalb bei **Zutritt, Inventar und sicheren Funknetzen**

Beratungsfrage: Welche Netzwerkzugänge sind für Gäste und Dritte erreichbar?

Vertrauen im lokalen Netzwerk

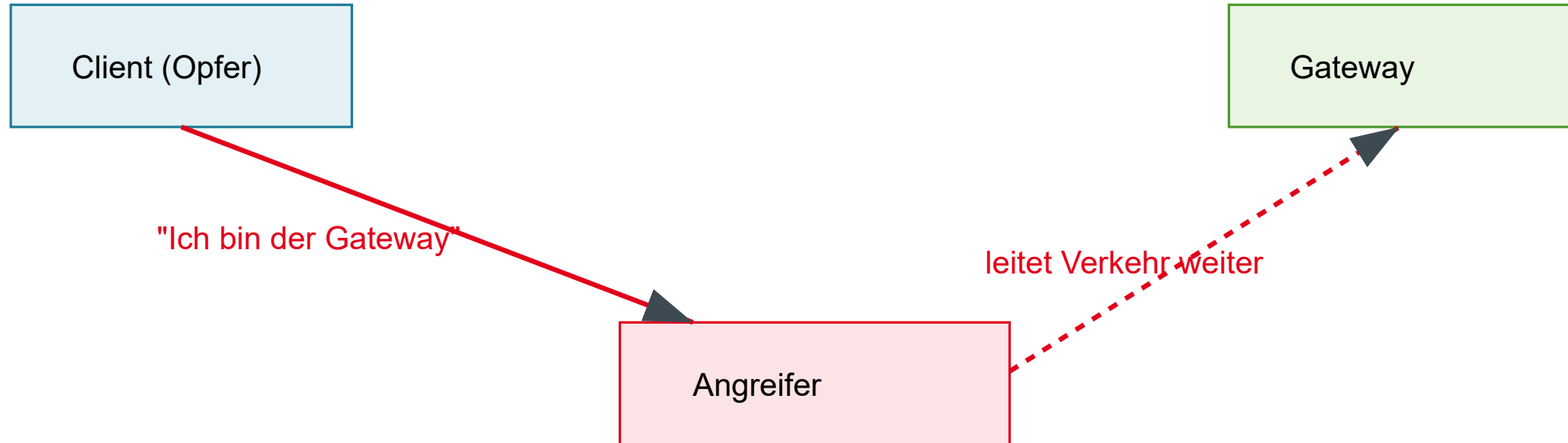
- Geräte im selben Netz müssen einander finden und Daten austauschen
- Ältere Netzwerkmechanismen vertrauen vielen Angaben ohne Identitätsprüfung
- Ein fremdes Gerät kann sich dadurch als legitimer Kommunikationspartner ausgeben
- Mögliche Folgen: **Mitlesen, Manipulation oder Zugriff auf weitere Systeme**

Nähe im Netzwerk ist kein Beweis für Vertrauenswürdigkeit.

Beispiel: Identität im Netzwerk vortäuschen

- Angreifer gibt sich im lokalen Netz als ein anderes Gerät aus
- Datenverkehr wird unbemerkt über den Angreifer geleitet
- Vergleichbar mit einer gefälschten Nachsendeadresse für Geschäftspost
- Risiken: Zugangsdaten mitlesen, Inhalte verändern, Kommunikation stören
- Fachbegriffe: **MAC-Spoofing** und **ARP-Spoofing**

ARP-Spoofing als Diagramm



Gefälschte ARP-Antwort lenkt den gesamten Verkehr des Clients über den Angreifer um

Datenwege im Internet

Wem vertrauen wir beim Transport?

Wie Daten ihr Ziel finden

- Daten werden in kleine Pakete aufgeteilt und über mehrere Stationen weitergeleitet
- **IP-Adressen** kennzeichnen Absender und Ziel
- Router wählen den verfügbaren Weg durch verschiedene Netze
- Unternehmen vertrauen dabei auf Infrastruktur außerhalb der eigenen Kontrolle

Schutz muss auch wirken, wenn der Transportweg nicht vertrauenswürdig ist.

Gefälschte Absender

- Absenderangaben in Netzwerkpaketen können manipuliert werden
- Angreifer verschleiern damit ihre Herkunft oder missbrauchen Vertrauen
- Gefälschte Adressen können Antworten gezielt an ein Opfer lenken
- Deshalb darf eine Adresse allein keine Identität beweisen

Beratungsfrage: Welche Zugriffe vertrauen nur auf Herkunft oder Standort?

Wenn digitale Wegweiser falsch zeigen

- Netzbetreiber tauschen Informationen über erreichbare Ziele aus
- Fehlerhafte oder manipulierte Angaben können Verkehr umleiten
- Mögliche Folgen: **Ausfall, Verzögerung, Überwachung oder Manipulation**
- Unternehmen reduzieren das Risiko durch Verschlüsselung und belastbare Provider
- Fachbeispiel: **BGP-Hijacking**

Kleine Anfrage, große Wirkung

- Angreifer nutzen viele fremde Systeme als unbeabsichtigte Verstärker
- Kleine Anfragen erzeugen zahlreiche oder deutlich größere Antworten
- Alle Antworten werden an die gefälschte Adresse des Opfers geschickt
- Ergebnis: Dienste werden langsam oder fallen vollständig aus

Das Angriffsziel ist **Verfügbarkeit**, nicht zwingend der Datendiebstahl.

Datenwege kontrollieren

- **Firewalls** prüfen Verbindungen anhand festgelegter Regeln
- Nur notwendige Kommunikationswege werden freigegeben
- Verschlüsselung schützt Inhalte auf fremden Transportwegen
- Überwachung erkennt ungewöhnliche Ziele, Mengen oder Muster
- Redundanz hält wichtige Dienste trotz einzelner Ausfälle erreichbar

Verfügbarkeit von Diensten

Wenn legitime Kommunikation zur Last wird

Zwei Arten der Datenübertragung

TCP

- Wie ein **Telefonat** mit Rückbestätigung
- Verbindung und Vollständigkeit werden geprüft
- Zuverlässig, aber mit zusätzlichem Aufwand
- Typisch für Webseiten und E-Mail

UDP

- Wie eine **Postkarte** ohne Empfangsbestätigung
- Daten werden direkt versendet
- Schnell, Verluste werden eher akzeptiert
- Typisch für Streaming und Namensabfragen

Beispiel: Unvollständige Anfragen blockieren

- Ein Dienst reserviert Ressourcen für neue Verbindungen
- Angreifer starten massenhaft Verbindungen, führen sie aber nie zu Ende
- Offene Anfragen belegen Speicher und Verarbeitungskapazität
- Legitime Kunden werden langsam oder abgewiesen
- Fachbeispiel: **SYN-Flood**

Aufklärung vor dem Angriff

- Angreifer prüfen systematisch, welche Dienste erreichbar sind
- Vergleichbar mit dem Testen von Türen und Fenstern vor einem Einbruch
- Die Suche ist automatisiert und findet dauerhaft im Internet statt
- Unnötige Dienste vergrößern die Angriffsfläche
- Fachbegriff: **Portscan**

Verfügbarkeit ist ein Geschäftsversprechen

- Online-Dienste müssen auch unter hoher Last erreichbar bleiben
- **DDoS-Angriffe** verteilen Überlastung auf viele Quellen
- Folgen: Umsatzverlust, Vertragsverletzungen, Supportaufwand, Vertrauensverlust
- Schutz: Kapazitätsreserven, Filterung, Notfallpläne und spezialisierte Anbieter

Beratungsfrage: Welche Ausfallzeit kann das Geschäft wirklich verkraften?

Anwendungen und Sitzungen

Wenn vertraute Dienste getäuscht werden

Nach dem Login: die digitale Sitzung

- Nach erfolgreicher Anmeldung merkt sich ein Dienst den Nutzer
- Ein **Sitzungstoken** dient vorübergehend als Nachweis der Anmeldung
- Wer dieses Token stiehlt, kann möglicherweise ohne Passwort handeln
- Verschlüsselung schützt das Token auf dem Transportweg
- Kurze Gültigkeit begrenzt den möglichen Schaden

Beispiel: Eine angemeldete Sitzung übernehmen

- Angreifer erbeutet den temporären Nachweis einer Anmeldung
- Der Dienst hält den Angreifer anschließend für den legitimen Nutzer
- Eine starke Anmeldung allein verhindert diesen Missbrauch nicht
- Schutz: verschlüsselte Verbindung, sichere Endgeräte, kurze Sitzungen
- Fachbegriff: **Session Hijacking**

Die Anwendung schafft Vertrauen

- Nutzer sehen Namen, Inhalte und Marken – nicht die Netzwerkprotokolle dahinter
- Vertraute Oberflächen können Sicherheit vermitteln, aber auch gefälscht werden
- Anwendungen verarbeiten wertvolle Daten und geschäftliche Transaktionen
- Technik, Prozesse und Aufmerksamkeit der Nutzer müssen zusammenspielen

Eine funktionierende Verbindung garantiert noch kein vertrauenswürdiges Gegenüber.

Beispiel: Der richtige Name, das falsche Ziel

- Das **Domain Name System (DNS)** übersetzt Namen in technische Zieladressen
- Manipulierte Antworten können Nutzer zu einem falschen Dienst leiten
- Der eingegebene Name kann dabei korrekt erscheinen
- Mögliche Folgen: Zugangsdaten- oder Zahlungsdatendiebstahl
- Fachbegriffe: **DNS-Spoofing** und **Cache-Poisoning**

Ein Muster, verschiedene Angriffswege

- Angreifer positioniert sich unbemerkt zwischen zwei Kommunikationspartnern
- Er kann Daten mitlesen, verändern oder an ein falsches Ziel leiten
- Der Einstieg ist über WLAN, lokales Netz oder Namensauflösung möglich
- **Ende-zu-Ende-Verschlüsselung** schützt den Inhalt über unsichere Wege

Fachbegriff: Man-in-the-Middle (MITM)

Wenn normale Anfragen zum Angriff werden

- Angreifer senden massenhaft scheinbar legitime Anfragen an eine Anwendung
- Einzelne Anfragen wirken unauffällig, ihre Menge überlastet den Dienst
- Botnetze verteilen den Verkehr auf viele Geräte und Regionen
- Schutz erfordert Erkennung, Skalierung und klare Prioritäten für kritische Dienste
- Fachbeispiel: **HTTP-Flood**

Verteidigung im Überblick

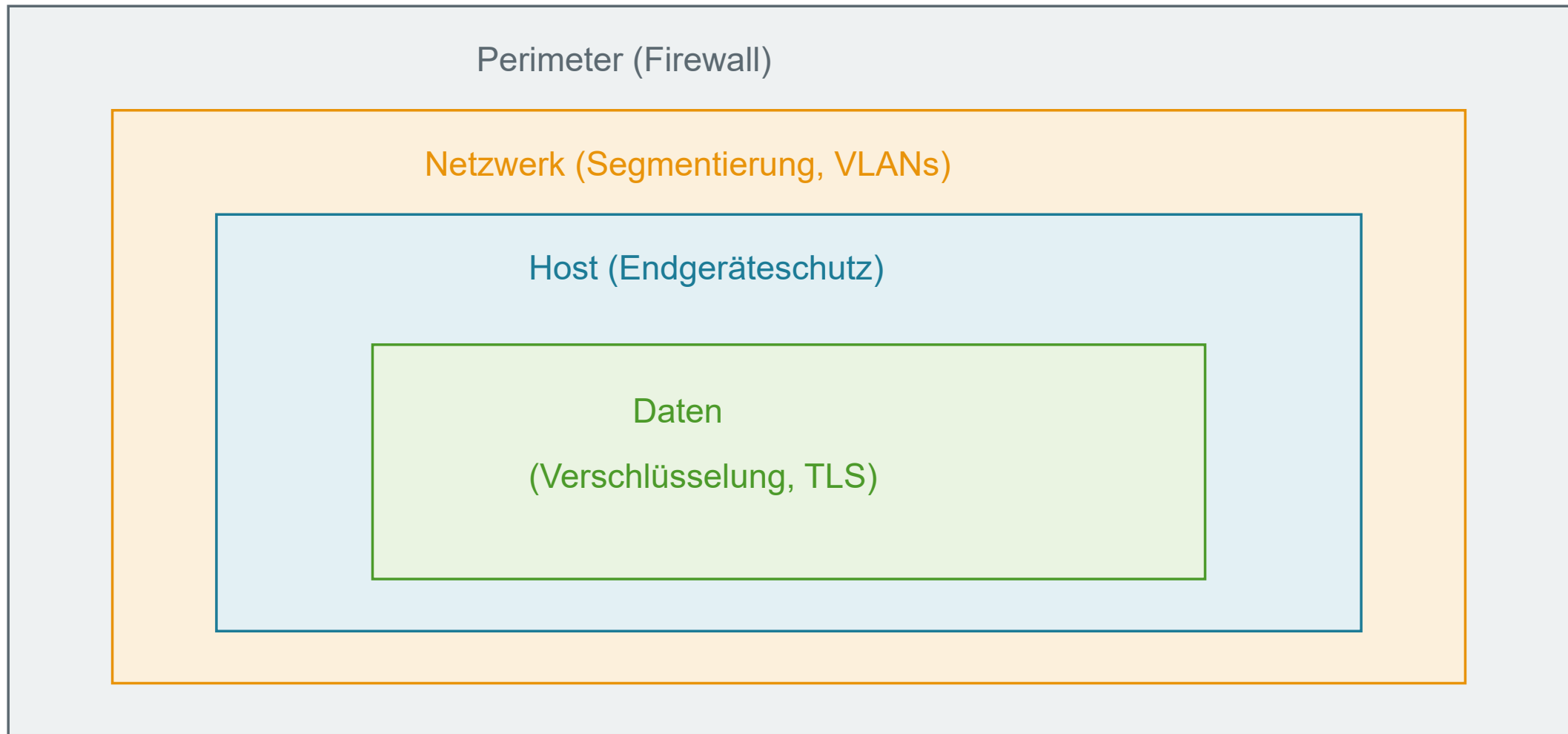
Mehrere Schutzlinien gleichzeitig

Defense in Depth

- **Defense in Depth** kombiniert mehrere unabhängige Schutzmaßnahmen
- Vorbeugen, Erkennen, Begrenzen und Wiederherstellen ergänzen sich
- Versagt eine Maßnahme, verhindert die nächste den Totalschaden
- Menschen, Prozesse, Technik und Dienstleister tragen gemeinsam bei

Nicht die Anzahl der Produkte zählt, sondern das Zusammenspiel der Kontrollen.

Defense in Depth als Diagramm



Schutzmaßnahmen nach ihrer Wirkung

Ziel	Beispiele	Nutzen
Vorbeugen	sichere Konfiguration, Firewall, Verschlüsselung	Eintritt erschweren
Begrenzen	Segmentierung, minimale Rechte	Ausbreitung stoppen
Erkennen	Protokollierung, Netzwerküberwachung	Vorfälle sichtbar machen
Reagieren	Notfallplan, DDoS-Dienstleister	Ausfallzeit verkürzen
Lernen	Tests, Übungen, Verbesserungsprozess	Wiederholung vermeiden

Netzwerksegmentierung & Zero Trust

- **Segmentierung** trennt Bereiche mit unterschiedlichen Aufgaben und Risiken
- Beispiel: Gäste, Büroarbeitsplätze, Produktion und kritische Server
- **Zero Trust** prüft Zugriffe anhand von Identität, Gerät und Kontext
- Gemeinsam reduzieren beide die unkontrollierte Ausbreitung eines Angriffs

Beratungsfrage: Was kann ein kompromittierter Arbeitsplatz im internen Netz erreichen?

Zusammenfassung

Bereich	Kernrisiko	Leitfrage
Zugang	fremde oder kompromittierte Geräte	Wer oder was darf sich verbinden?
Transport	Umleitung, Mitlesen, Überlastung	Wie bleiben Daten und Dienste geschützt?
Anwendung	Täuschung und Sitzungsübernahme	Ist das Gegenüber wirklich vertrauenswürdig?
Organisation	unklare Reaktion und Abhängigkeiten	Wer handelt bei einem Vorfall?

Merksatz: Netzwerksicherheit schützt Geschäftskontinuität, Daten und Vertrauen.

Diskussionsfragen

- Welcher netzwerkbedingte Ausfall hätte bei eurem Partnerunternehmen die größten Folgen?
- Mit welchen drei Fragen würdet ihr ein erstes Kundengespräch beginnen?
- Wo könnte sich ein Angreifer nach einem erfolgreichen Einstieg weiter ausbreiten?
- Wie würdet ihr den Nutzen von Segmentierung ohne Fachbegriffe erklären?
- Welche Schutzmaßnahme benötigt zwingend einen organisatorischen Prozess?